



Trust, but Verify

The New Rules of Open Source

AlmaLinux Day Los Angeles

2026

The Open Source

Open source gives us the building blocks we need today to support our businesses.

Enterprise Linux, and specifically AlmaLinux, provides the exact stability we need to actually run it safely.

As leaders, our job is to build a secure wall between the absolute chaos of open-source and the stability of our operating systems.

And that wall is currently being tested.



Are we ready for vulnerabilities at machine speed?

The XZ Utils Wake-up Call

(A Breach of Trust)



We Have Crossed a Threshold

75%

of new code at Google is AI-generated

Moving Faster Than Ever

On a global scale, GitHub officially reported that **51%** of all committed code is now AI-generated or AI-assisted.

We are watching AI rapidly dominate the coding space, but this unprecedented speed has a hidden cost.

The Cost of Speed



In testing by Veracode, nearly half of AI-generated code introduced critical security vulnerabilities (100 LLMs across tests from Python, JavaScript, and C#).

AI models aren't malicious; they simply optimize for code that runs, not code that is secure.

But where are the real dangers?



Slopsquatting

AI hallucinated a
(huggingface-cli
uploaded with th
30,000 blind dev
in just 3 months.



Blind Trust

without a second thought.



AI Autonomy

every principle I was given."

+ Ask Gemini

Flash



Gemini is AI and can make mistakes.

powered
cketOS).
violated

But let's ask ourselves, why is
this so dangerous?

The Autopilot Analogy

(As It Pertains to Cognitive Atrophy)



The Defenders' Advantage



We Cannot Un-invent AI

We must use it defensively. Our goal is to ensure our AI defenders are moving faster than the AI attackers.

-  **Google's Magika:** Identifying malware files with 99% accuracy in milliseconds.
-  **Deep Hunting:** AI recently found a critical 15-year-old root bug in Linux.
-  **Workforce Multiplier:** Empowering junior analysts to hunt for complex threats.

Building Guardrails (Part 1)

-  **Vulnerability Scans:** Never stop scanning your systems for new vulnerabilities that are being reported daily. CVEs exists for your knowledge and protection.
-  **Shift Mindsets:** Developers must transition from writers to reviewers. Mandatory architectural reviews are tedious, but they are absolutely necessary to validate code for weaknesses.
-  **Prompt for Security:** Hardcode security constraints directly into your AI prompts. If you don't prompt the AI to build it securely, it will neglect safety at release.
-  **Use Private Registries:** Route install commands through an internal, pre-vetted AlmaLinux server to quarantine your environment.

Building Guardrails (Part 2)

-  **Mandatory SBOMs:** If you can't see the dependency tree, you can't defend it. Generate SBOMs for the software you build and integrate them into your CI/CD pipelines.
-  **Terminal Wrappers:** Intercept AI hallucinations locally before they execute. Prevent hallucinated packages from deploying inside your environment.
-  **Zero Trust for AI Agents:** Treat autonomous AI package installations as a highly privileged operation. Do not give them blanket bypass access to your servers.

And Many More....

Trust, but Verify.

Our tools will evolve, but our philosophy cannot.
Demand checks and balances for every major
decision.

Sources

<https://nvd.nist.gov/vuln/detail/CVE-2024-3094>

https://www.youtube.com/watch?v=8XnRd_cnjoo

<https://finitestate.io/blog/uncovering-the-critical-vulnerability-in-xz-utils-with-the-finite-state-next-generation-platform>

<https://gloss.run/post/half-of-all-code-on-github-is-now-ai-generated>

<https://blog.google/innovation-and-ai/infrastructure-and-cloud/google-cloud/cloud-next-2026-sundar-pichai/>

<https://uvm.net/blog/ai-code-generation-statistics/>

<https://www.securitymagazine.com/articles/101801-ai-introduces-security-vulnerabilities-within-code-in-45-of-cases>

<https://www.veracode.com/blog/genai-code-security-report/>

<https://www.youtube.com/watch?v=tgefVQotJqc>

<https://en.wikipedia.org/wiki/Slopsquatting>

<https://www.lasso.security/blog/ai-package-hallucinations>

<https://www.theguardian.com/technology/2026/apr/29/claude-ai-deletes-firm-database>

<https://www.wired.com/story/loss-of-physical-world-book-excerpt-the-small-stuff-ian-bogost/>

<https://github.com/google/magika>

<https://www.wired.com/story/security-news-this-week-ai-found-a-root-bug-in-linux-that-everyone-missed-for-15-years/>

<https://www.weforum.org/stories/2026/05/how-ai-could-open-up-cybersecurity-to-a-wider-workforce>